

CONFIDENTIAL WEBSITE AUDIT REPORT

CyberAI UZ

Security, Performance, UI/UX, Accessibility, SEO and Code Quality Review

Field	Value
Website	https://app.cyberaiuz.workers.dev
Repository	Local workspace D:\cyberaiuz; remote URL returned GitHub 404 during public check
Audit date	2026-07-04
Timezone	Asia/Tashkent
Method	Passive browser testing, HTTP/API observation, local source review, npm lint/test/audit
Excluded	No brute force, DoS, credential stuffing, destructive exploitation, or intrusive scanning

Scope warning: Agressiv pentest uchun alohida yozma tasdiq talab qilinadi. Bu hisobot passiv va past-xavfli tekshiruv natijalariga asoslangan.

Table of Contents

#	Section
1	Executive Summary
2	Scope, Methodology and Evidence
3	UI/UX Audit
4	Frontend Code Review
5	Backend and Architecture Review
6	Security Audit - OWASP Top 10
7	Performance Audit
8	SEO Audit
9	Accessibility Audit
10	Functional Testing
11	Bug Report
12	Positive Findings
13	Improvement Roadmap
14	Final Verdict
15	Appendices

Note: Word can regenerate page numbers if an automatic TOC is required. This report uses a stable manual contents table to keep layout deterministic in headless rendering.

1. Executive Summary

CyberAI UZ is a polished AI-cybersecurity web platform deployed on Cloudflare Workers with TanStack Start, React, D1, R2, KV, Queues, Durable Objects and multiple API surfaces. The site is visually strong and Core Web Vitals are good in lab measurements, but the security and maintainability posture is not production-grade yet.

Final verdict: Not production-ready for sensitive users until admin authorization, CSP, dependency vulnerabilities, lint failures and asset/caching issues are fixed.

Area	Score	Reason
Overall	68/100	Good presentation, but serious security and maintainability gaps remain.
Security	58/100	Strong baseline headers and cookies, weakened by admin authorization flaw, CSP unsafe directives, dependency advisories and information leakage.
Performance	76/100	Good vitals, but oversized icons/logo and weak immutable caching reduce quality.
UI/UX	78/100	Modern visual system, responsive layout, clear theme; usability/accessibility issues in clickable cards and icon buttons.
Accessibility	62/100	Semantic headings exist, but unnamed icon buttons, div-click cards, small tap targets and missing autocomplete hurt compliance.
SEO	70/100	Title, description, OG/Twitter, sitemap and robots exist; canonical/structured data URLs are wrong or relative.
Code Quality	55/100	Tests pass, but lint has 737 errors and 12 warnings.
Maintainability	60/100	Reasonable architecture, but formatting drift, mixed security patterns and generated/static assets add operational risk.

2. Scope, Methodology and Evidence

Observed Evidence

Evidence	Observation
HTTP headers	curl -I returned HSTS, CSP, X-Frame-Options, nosniff, referrer-policy, permissions-policy.
CSP weakness	script-src includes 'unsafe-inline' and 'unsafe-eval'; server generates nonce but injectNonceIntoHtml returns the HTML unchanged.
API behavior	/api/auth/me returned {ok:false,user:null}; POST /api/auth/login with empty JSON returned 400 validation error.
CORS	Cross-origin OPTIONS request did not expose Access-Control-Allow-Origin; it returned HTML rather than a useful API preflight response.
Performance	agent-browser vitals: TTFB 175.22 ms, FCP 840.54 ms, LCP 1774.26 ms, CLS approximately 0.
Assets	brand-logo/favicon/apple-touch-icon are 1,343,203 bytes each; runtime transfer showed repeated 1.34 MB image downloads.
Responsive	390x844 and 768x1024 viewports had no horizontal overflow.
Tests	Vitest: 8 test files passed, 46 tests passed.
Lint	ESLint failed: 749 problems, 737 errors, 12 warnings.
Dependencies	npm audit --omit=dev reported 13 vulnerabilities: 7 high, 5 moderate, 1 low.

Testing Limitations

- GitHub public page for the provided repository URL returned 404 in web check; local repo and remote config were available.
- No authenticated user credentials were provided; authenticated dashboard, billing and admin flows were reviewed from code and unauthenticated responses only.
- No aggressive vulnerability scanning, brute force, DoS, exploitation, credential attacks or destructive tests were performed.
- SQL injection, SSRF, IDOR and upload exploitation were not actively exploited; code and request behavior were reviewed.

Risk Matrix

Likelihood / Impact	Low Impact	Medium Impact	High Impact
High Likelihood	Medium	High	Critical
Medium Likelihood	Low	Medium	High
Low Likelihood	Info	Low	Medium

Top 10 Weaknesses

1. Admin challenge API checks only authentication, not admin authorization.
2. CSP allows unsafe-inline and unsafe-eval, weakening XSS containment.
3. Production dependencies include high severity advisories.
4. Lint fails with 737 errors; codebase is not CI-clean.
5. 1.34 MB logo is reused as favicon and app icon.
6. Static assets use Cache-Control max-age=0 despite hashed filenames.
7. Several API catch blocks expose raw error messages or upstream details.
8. Prompt cache key uses only the first 100 characters of sanitized message.
9. Interactive cards use generic div onclick instead of keyboard-native buttons/links.
10. Icon-only copy buttons lack accessible names and have 28px tap targets.

3. UI/UX Audit

Design Consistency

The visual direction is coherent: dark operational aesthetic, strong primary/accent palette, consistent rounded panels, motion-rich hero, and security-domain copy. The design feels intentional rather than generic.

Typography and Visual Hierarchy

The hero hierarchy is strong and H1/H2/H3 levels appear in accessible snapshots. However, some text strings concatenate in accessible output, for example 'Talk to yourinfrastructure.', indicating spacing/inline markup issues that should be reviewed.

Responsiveness

Mobile and tablet checks showed no horizontal overflow. Navigation collapses on mobile, and primary CTAs remain visible. Mobile icon buttons and category tabs are compact; several controls are below comfortable touch size.

Navigation and User Flow

The top navigation exposes major product areas clearly: Console, VAEL AI, Leaderboard, Dashboard, Targets and Threats. CTA buttons are visible. The 'Start for Free' button opens auth intent but should be verified with authenticated registration end-to-end.

Forms and States

Auth forms have labels, disabled states, password strength feedback and inline errors. Missing autocomplete attributes and autoFocus on modal fields reduce polish and mobile ergonomics.

Area	Observed Strength	Observed Weakness	Fix
Navigation	Clear product routes	More menu behavior not deeply verified	Add E2E tests for menu open/close and keyboard nav.
Buttons	Consistent visual styling	Icon-only copy buttons unnamed	Add aria-label and 44px hit target.
Animations	High production feel	Heavy motion without verified reduced-motion pass	Use prefers-reduced-motion variants.
Empty states	Prompt search has empty state	Some API/dashboard empty/error states unverified without auth	Add fixture-driven tests.

4. Frontend Code Review

HTML and Semantic Quality

SSR output includes valid title, meta tags, language attribute, headings and navigation links. Problems are concentrated in interactive components: clickable generic containers and unnamed icon buttons.

CSS Architecture

Tailwind-style utility classes are used consistently, but global CSS and visual components are large. The app uses multiple animation libraries and custom visual components, so regression testing is important.

JavaScript Quality

React/TanStack architecture is modern. However, lint output is not acceptable for a production codebase: 749 total problems, mostly Prettier errors, plus real warnings such as a missing React hook dependency.

Component Reusability

Reusable components exist for inputs, dialog, navbar, status pills and cards. Some feature components contain large hardcoded datasets and UI logic in the same file, making long-term maintenance harder.

Accessibility Implementation

Labels exist for auth fields, but autocomplete attributes are missing. Prompt/project cards should become buttons or links with keyboard handlers, and copy buttons need accessible names.

5. Backend and Architecture Review

API Behavior

APIs return structured JSON for auth endpoints and text streams for AI chat. Unauthenticated `/api/auth/me` returns a safe null user response. Validation exists for missing login fields.

Authentication and Session Handling

Session cookie is `HttpOnly`, `Secure` and `SameSite=Strict` with a 7-day TTL. Session tokens are random 32-byte values stored as SHA-256 hashes. This is a good baseline.

Authorization

Authorization is inconsistent. User profile, settings, target creation and analytics routes verify session ownership. The admin challenge route verifies only that a user is logged in, not that the user has an admin role.

Rate Limiting and Quotas

Cloudflare rate limit bindings are configured for global, chat, auth and API categories, with D1 fallback. The fallback returns `allowed=true` if storage fails, which favors availability over abuse resistance.

Server Responses

Security headers are applied broadly. Some routes return `err.message` or `String(err)`, which can leak internal details if unexpected exceptions occur.

6. Security Audit - OWASP Top 10

OWASP Area	Status	Evidence
Broken Access Control	High issue found	Admin challenge API lacks admin role check.
Cryptographic Failures	Medium issue found	PBKDF2 100k and non-constant string compare.
Injection	Partially mitigated	D1 prepared statements observed; prompt/cache and XSS surfaces still need hardening.
Insecure Design	Medium issue found	Admin route design trusts any authenticated user.
Security Misconfiguration	Medium issue found	CSP unsafe directives; stale X-XSS-Protection.
Vulnerable Components	High issue found	npm audit: high advisories in vite, hono, undici, ws.
Identification/Auth Failures	Medium issue found	Password KDF and no explicit password complexity server-side beyond length.
Software/Data Integrity	Low/Medium	No SRI for Google Fonts; service worker cache strategy needs version discipline.
Logging/Monitoring	Mixed	Sentry/analytics present; console logging of errors/upstream details present.
SSRF	Tekshirib bo'lmadi	No active SSRF probes; external fetches are fixed provider URLs in reviewed code.

SEC-01. Admin Challenge API Allows Any Authenticated User

Severity	High
Category	Broken Access Control / Authorization
Description	The /api/admin/challenges route checks for a valid session but does not check an admin role, permission claim, allowlist or policy.
Impact	Any normal logged-in user could list, create, update or delete challenges if they can reach the endpoint. That is a direct privilege escalation risk.
Evidence	src/routes/api/admin/challenges.tsx validates token and session.user, then executes SELECT/INSERT/UPDATE/DELETE. No role check was observed.
Recommendation	Add a server-side requireAdmin() guard backed by DB role/permission data. Apply it to all admin handlers and add negative tests for normal users.

SEC-02. CSP Uses unsafe-inline and unsafe-eval

Severity	High
Category	XSS / Security Headers
Description	The CSP advertises protection but explicitly permits inline script and eval. A nonce is generated in server.ts but injectNonceIntoHtml returns unchanged HTML.
Impact	If any XSS sink appears, the current CSP is unlikely to contain it. unsafe-eval also expands the blast radius of dependency or script injection issues.
Evidence	curl -I showed: script-src 'self' 'unsafe-inline' 'unsafe-eval'. Code: src/server.ts buildCSP() and injectNonceIntoHtml().
Recommendation	Remove unsafe-eval, replace inline scripts with nonce or hashes, inject the generated nonce into SSR scripts, and run CSP in Report-Only before enforcement.

SEC-03. High Severity Dependency Advisories

Severity	High
Category	Vulnerable and Outdated Components
Description	npm audit --omit=dev reported 13 vulnerabilities: 7 high, 5 moderate, 1 low. High advisories include hono, undici, vite and ws.
Impact	Even if some issues are dev-server or adapter-specific, untriaged high advisories are not acceptable for a production security platform.
Evidence	npm audit output listed GHSA advisories for hono path traversal/CORS issues, undici TLS/header/cache issues, vite Windows fs/NTLM issues, and ws DoS.
Recommendation	Run npm audit fix where non-breaking, upgrade Cloudflare/Vite stack in a controlled branch, document non-applicable advisories, and enforce Dependabot/Snyk in CI.

SEC-04. Raw Error Messages Can Leak Internal Details

Severity	Medium
Category	Information Disclosure / Error Leakage
Description	Several API catch blocks return <code>err.message</code> or <code>String(err)</code> directly to clients.
Impact	Unexpected database, provider or runtime errors can reveal implementation details, table names, provider behavior or environment assumptions.
Evidence	Observed in <code>src/routes/api/user/profile.tsx</code> , <code>api/targets.tsx</code> , <code>api/leaderboard.tsx</code> , <code>api/threats.tsx</code> , <code>api/zkp.tsx</code> and others.
Recommendation	Return stable public error codes/messages. Log detailed errors only to server telemetry with request IDs.

SEC-05. Password Hashing is Below Current Best Practice

Severity	Medium
Category	Authentication / Credential Storage
Description	Passwords are hashed with PBKDF2-SHA256 at 100,000 iterations and verified with computed === stored.
Impact	PBKDF2 is acceptable only with carefully tuned parameters, but Argon2id/bcrypt/scrypt are stronger defaults for password storage. Non-constant comparison can leak timing information in principle.
Evidence	src/lib/auth/auth-server.ts defines PBKDF2_ITERATIONS = 100_000 and verifyPassword returns computed === stored.
Recommendation	Use Argon2id or bcrypt with calibrated cost if runtime permits. If staying on PBKDF2, increase iterations and use constant-time comparison.

SEC-06. Server Allows User-Supplied systemPrompt in Chat API

Severity	Medium
Category	AI Security / Prompt Injection
Description	The chat API accepts body.systemPrompt and wraps it with createSecureSystemPrompt. This still gives clients influence over the highest-priority model instruction content.
Impact	Users can steer model behavior far beyond normal user message intent. Regex-based prompt injection detection is brittle and can overblock benign input while missing transformed attacks.
Evidence	src/routes/api/chat.tsx uses body.systemPrompt ? createSecureSystemPrompt(body.systemPrompt) : undefined.
Recommendation	Do not accept arbitrary system prompts from public clients. Use server-owned prompt templates and pass user preferences as data, not instructions.

SEC-07. Prompt Cache Key Can Collide Across Different Messages

Severity	Medium
Category	Data Integrity / Privacy
Description	The cache key includes only selected model, image flag and sanitizedMessage.slice(0, 100), while getCachedResponse also receives messages.
Impact	If the lower cache layer keys primarily on the supplied key, different prompts sharing the first 100 characters could receive the wrong cached response.
Evidence	src/routes/api/chat.tsx builds cacheKey = groq:\${selectedModel}:...\${sanitizedMessage.slice(0, 100)}.
Recommendation	Use SHA-256 over normalized full model + full message + relevant history + system template version. Do not key on short prefixes.

SEC-08. CSRF Token Not Implemented for Cookie-Based Mutations

Severity	Medium
Category	CSRF
Description	Cookie auth uses SameSite=Strict, which is strong, but mutating routes do not include explicit CSRF tokens.
Impact	SameSite=Strict blocks many cross-site attacks, but explicit CSRF defenses are still recommended for sensitive mutation endpoints and future domain changes.
Evidence	Session cookie: HttpOnly; Secure; SameSite=Strict. Mutating routes accept JSON without CSRF token observed.
Recommendation	Add origin checks and CSRF tokens for authenticated state-changing routes. Keep SameSite=Strict as defense-in-depth.

SEC-09. Avatar Upload Trusts Browser MIME Type

Severity	Medium
Category	File Upload
Description	Avatar upload validates file.type and size, but no magic-byte validation or image re-encoding was observed.
Impact	A crafted payload with a spoofed MIME type may reach storage. Browser rendering limits risk, but stored file handling should not trust client metadata.
Evidence	src/routes/api/user/avatar.tsx allows image/jpeg, image/png, image/webp based on file.type and max 2 MB.
Recommendation	Validate magic bytes, decode/re-encode server-side, strip metadata, and serve with fixed Content-Type and X-Content-Type-Options.

SEC-10. Rate Limit Fallback Fails Open

Severity	Medium
Category	Abuse Prevention
Description	If both Cloudflare rate limiting binding and D1 fallback fail, checkRateLimit returns allowed: true.
Impact	During storage or binding outages, abusive traffic can bypass limits exactly when the system is degraded.
Evidence	src/lib/auth/rate-limit.ts final catch returns { allowed: true, remaining: 1, resetAt: 0 }.
Recommendation	Fail closed for auth and expensive AI routes, or use a conservative in-memory/edge fallback with short TTL.

SEC-11. Security Policy File is Template Text

Severity	Low
Category	Governance
Description	SECURITY.md still contains placeholder language such as 'Use this section to tell people...'
Impact	Security researchers and users do not have a trustworthy vulnerability reporting path or supported-version policy.
Evidence	SECURITY.md in repo contains generic template rows and placeholder instructions.
Recommendation	Replace with real contact, SLA, scope, safe harbor, disclosure process and supported versions.

SEC-12. CORS Preflight Behavior is Not API-Friendly

Severity	Low
Category	CORS / API Behavior
Description	Cross-origin OPTIONS to /api/auth/login returned 200 HTML instead of a clear method policy or CORS response.
Impact	This does not appear to allow cross-origin credentialed requests, but it is confusing for API consumers and test tooling.
Evidence	curl OPTIONS with Origin evil.example returned text/html and no Access-Control-Allow-Origin.
Recommendation	Return 204/405 for OPTIONS consistently and set explicit CORS policy for API routes.

7. Performance Audit

Core Web Vitals

Metric	Observed Value	Rating	Evidence
TTFB	175.22 ms	Good	agent-browser vitals
FCP	840.54 ms	Good	agent-browser vitals
LCP	1774.26 ms	Good	agent-browser vitals
CLS	0.0 approx	Good	agent-browser vitals
INP	Tekshirib bo'lmadi	Not measured	No meaningful interaction trace in vitals output.

Asset and Network Findings

- Largest static asset in dist/client/assets: brand-logo-BgXj89Up.png at 1,343,203 bytes.
- index-BmpIMQX0.js is 925,216 bytes on disk; index-bfmM3hBL.js is 685,084 bytes on disk.
- Runtime transfer showed brand logo, favicon and apple-touch-icon each transferring about 1.34 MB.
- Hashed JS/CSS assets return Cache-Control: public, max-age=0, must-revalidate instead of long immutable caching.

Recommendations

11. Generate real favicon sizes: 32x32, 48x48, 180x180, 192x192 and 512x512; do not reuse a 1.34 MB source PNG.
12. Set immutable cache headers for hashed assets: public, max-age=31536000, immutable.
13. Split large route bundles and audit animation/three.js usage for pages where it is not needed.
14. Add Lighthouse/agent-browser vitals budget checks to CI.

8. SEO Audit

Check	Status	Evidence / Fix
Title	Pass	CyberAI - Autonomous Defense for the Synthetic Era.
Meta description	Pass	Description exists and is concise.
OpenGraph	Partial	OG tags exist, but og:url is relative '/' and schema URL points to cyberaiuz.lovable.app.
Twitter cards	Pass	summary_large_image configured.
Sitemap	Pass	/sitemap.xml returns URL set with core pages.
Robots	Pass	/robots.txt exists and blocks API/admin/debug paths.
Canonical	Partial	Canonical href is '/', should be absolute production URL.
Structured data	Partial	Organization and WebSite exist but URL uses old lovable.app domain.
Heading hierarchy	Pass	H1 and H2/H3 hierarchy observed.
Broken links	Tekshirib bo'lmadi	No full crawl performed.

9. Accessibility Audit

WCAG-Oriented Findings

- Positive: semantic headings and real links/buttons are present in major navigation and forms.
- Problem: project and prompt cards appear as generic clickable elements with onclick. These are not keyboard-native controls.
- Problem: icon-only copy buttons have no accessible name in the browser snapshot.
- Problem: mobile tap targets for several icon buttons are 28x28 px, below the common 44x44 px target guideline.
- Problem: auth inputs do not show autocomplete attributes in source review.
- Problem: motion-heavy UI needs a verified prefers-reduced-motion pass.

Fixes

15. Use <button> for expandable cards or <a>/<Link> for navigation; add keyboard semantics only when native controls cannot be used.
16. Add aria-label='Copy prompt' / 'Copy template' to icon-only buttons.
17. Increase mobile icon button hit areas to at least 44x44 px.
18. Add autocomplete='email', 'current-password', 'new-password', 'one-time-code' where appropriate.
19. Add automated axe or Playwright accessibility checks.

10. Functional Testing

Feature	Observed Result	Status
Home page	Loaded successfully and rendered content.	Pass
Navigation links	Major links visible in snapshot.	Partial
Login validation	POST empty body returned 400 Email and password required.	Pass
Register	Reviewed from code; no live registration performed.	Tekshirib bo'lmasi
Logout	Reviewed from code; no authenticated session available.	Tekshirib bo'lmasi
Search prompts	Search textbox present; filtering behavior not exhaustively recorded.	Partial
Dashboard	No credentials provided; authenticated state not tested.	Tekshirib bo'lmasi
API interactions	/api/auth/me and /api/auth/login tested unauthenticated.	Partial
Notifications	Auth error UI present in code; live toast/notification behavior not exhaustively tested.	Partial

11. Bug Report

ID	Severity	Bug	Repro	Expected	Actual	Fix
BUG-01	High	Authenticated non-admin can access admin challenge API in code path	Login as normal user, call /api/admin/challenges	403 Admin required	200/list or mutation possible if session valid	Add requireAdmin guard.
BUG-02	High	CSP nonce not applied	Inspect src/server.ts and response headers	Nonce-based CSP without unsafe directives	unsafe-inline/unsafe-eval present; nonce ignored	Inject nonce and remove unsafe directives.
BUG-03	Medium	1.34 MB favicon/app icon	Inspect public/favicon.png and runtime resources	Small optimized icons	favicon/apple icon/logo are 1.34 MB	Generate resized icons.
BUG-04	Medium	Icon copy buttons inaccessible	Open accessibility snapshot	Named controls	Buttons appear without label	Add aria-label.
BUG-05	Medium	ESLint fails	Run npm run lint	0 errors	737 errors, 12 warnings	Run format and fix real lint warnings.
BUG-06	Low	SECURITY.md placeholder	Open SECURITY.md	Real disclosure process	Template text remains	Write actual policy.

12. Positive Findings

- Strong baseline transport security: HTTPS, HSTS preload-style header, nosniff and frame denial are present.
- Session cookie is HttpOnly, Secure and SameSite=Strict.
- Prepared SQL statements with bind parameters are widely used in D1 access paths.
- Rate limiting exists at Cloudflare binding level with category-specific limits.
- Email verification, password reset tokens and optional 2FA are implemented.
- Core Web Vitals lab results are good despite asset issues.
- Responsive layout avoids horizontal overflow on tested mobile and tablet sizes.
- Robots.txt and sitemap.xml are present.
- Vitest suite is present and passed 46 tests.
- The product UI is visually distinctive and domain-appropriate for cybersecurity.

13. Improvement Roadmap

Priority	Actions
Critical fixes	None confirmed as Critical in passive scope. Treat SEC-01 as urgent before production.
High Priority	Fix admin authorization; remove CSP unsafe directives; remediate dependency advisories; make lint CI-clean.
Medium Priority	Optimize icons/assets; fix immutable cache headers; harden password hashing; add CSRF tokens; remove raw error leakage.
Low Priority	Replace SECURITY.md placeholder; improve CORS OPTIONS behavior; tune robots.txt to avoid implying sensitive paths exist.
Nice to Have	Add automated Lighthouse, axe, bundle analyzer and dependency scanning gates.

14. Final Verdict

CyberAI UZ is visually impressive and technically ambitious, but it is not ready for sensitive production use. The biggest issue is not one isolated bug; it is the gap between the product's security positioning and the current operational discipline in authorization, CSP, dependency hygiene and lint cleanliness.

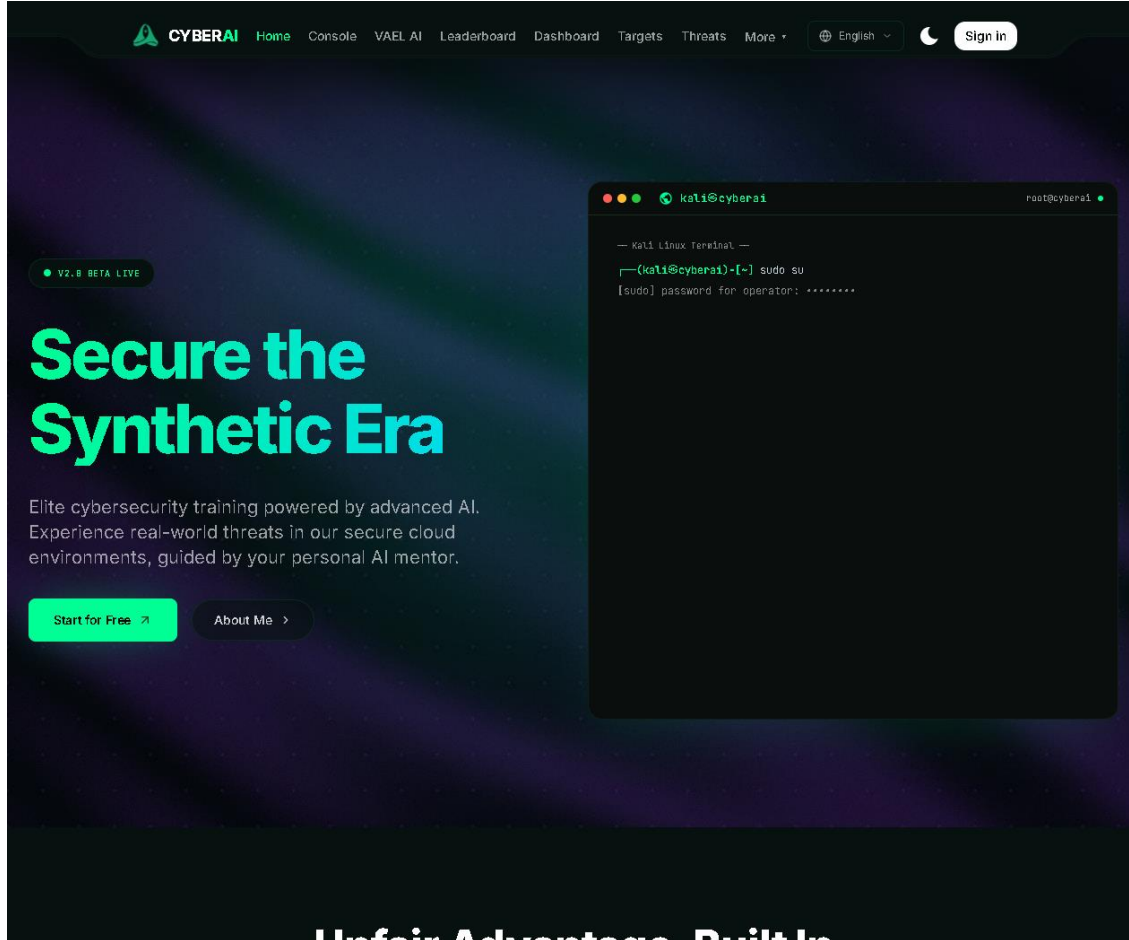
Production readiness: No - not for a real security product until High findings are fixed and authenticated flows are retested.

Question	Answer
Production-ready?	No, not for high-trust or security-sensitive users.
Estimated professional maturity	68%
Best area	Visual design and initial performance.
Weakest area	Security authorization and maintainability discipline.
Retest required?	Yes: after fixes, with authenticated accounts and full active test authorization.

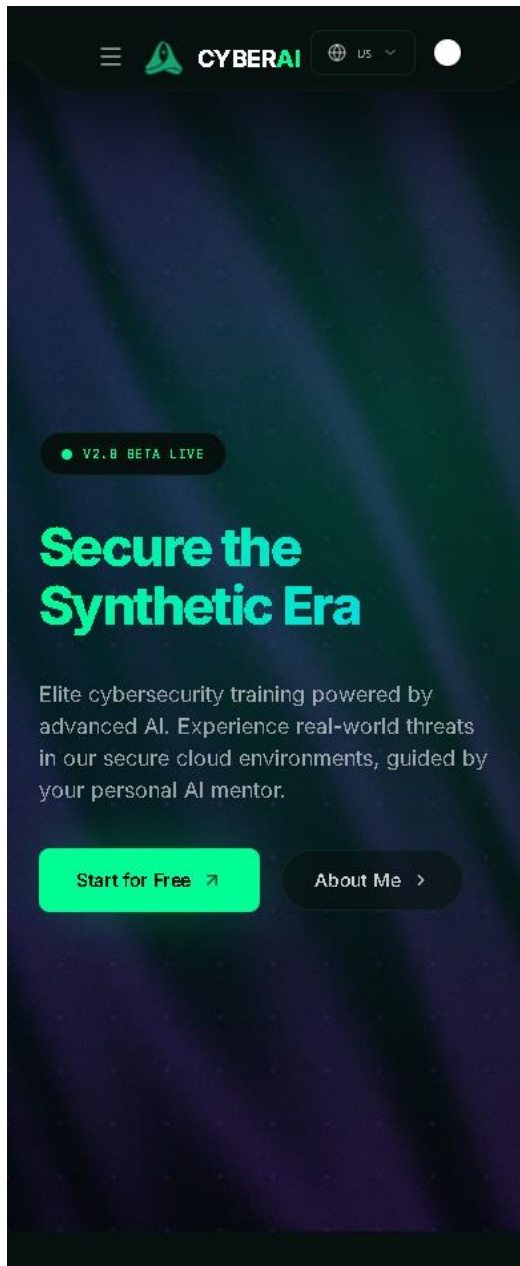
15. Appendices

Screenshot Evidence

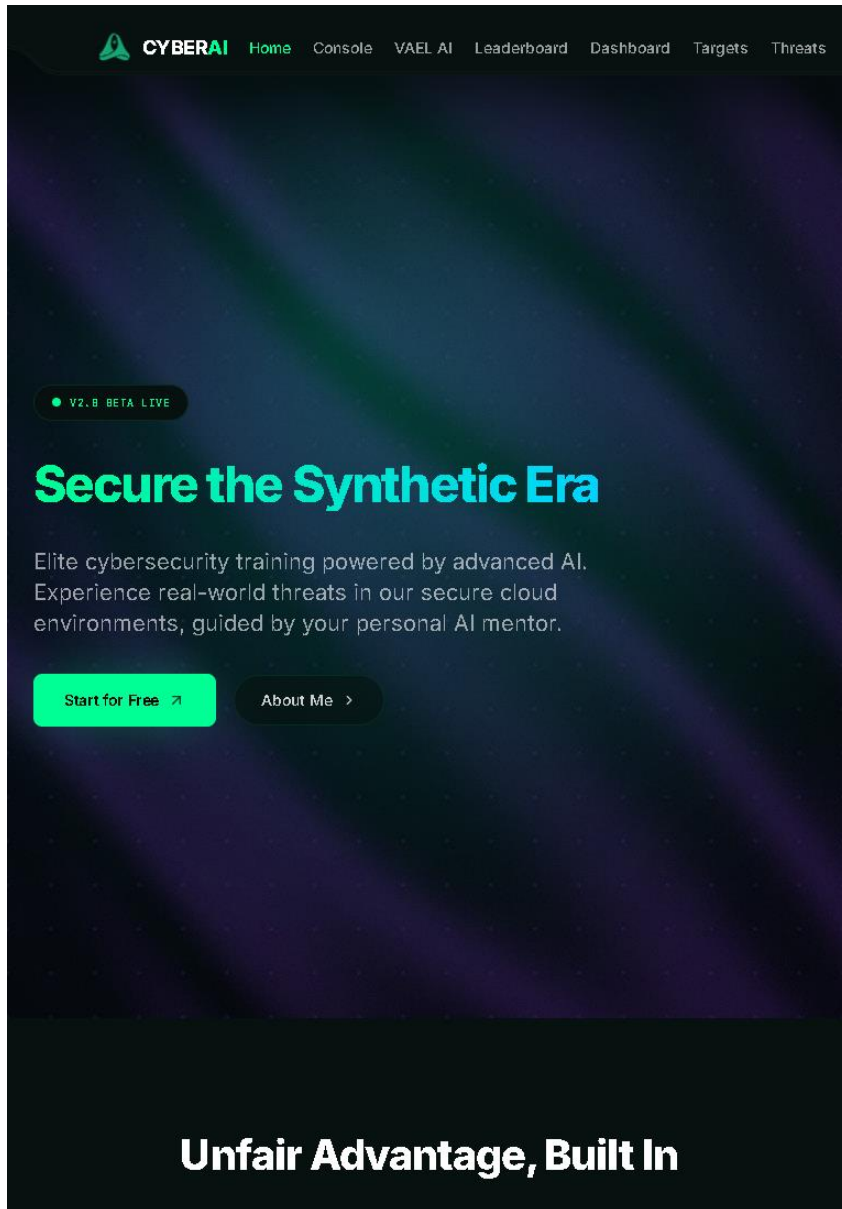
Desktop screenshot evidence - top viewport crop from full-page capture



Mobile screenshot evidence - top viewport crop from 390px full-page capture



Tablet screenshot evidence - top viewport crop from 768px full-page capture



Command Results Summary

Command	Result
npm run test:run	8 test files passed, 46 tests passed.
npm run lint	Failed: 749 problems, 737 errors, 12 warnings.
npm audit --omit=dev	13 vulnerabilities: 7 high, 5 moderate, 1 low.
agent-browser vitals	TTFB 175.22 ms, FCP 840.54 ms, LCP 1774.26 ms, CLS approx 0.
curl -I	Security headers present; CSP unsafe directives present.

Not Verified

- Authenticated dashboard workflow without credentials.
- Real registration email delivery inbox verification.
- Logout with a valid production session.
- Admin route exploitability with a real non-admin account.
- Full broken-link crawl.
- Active SQL injection, SSRF, IDOR or upload exploitation.
- JWT security: no JWT was observed; session cookie model is used.